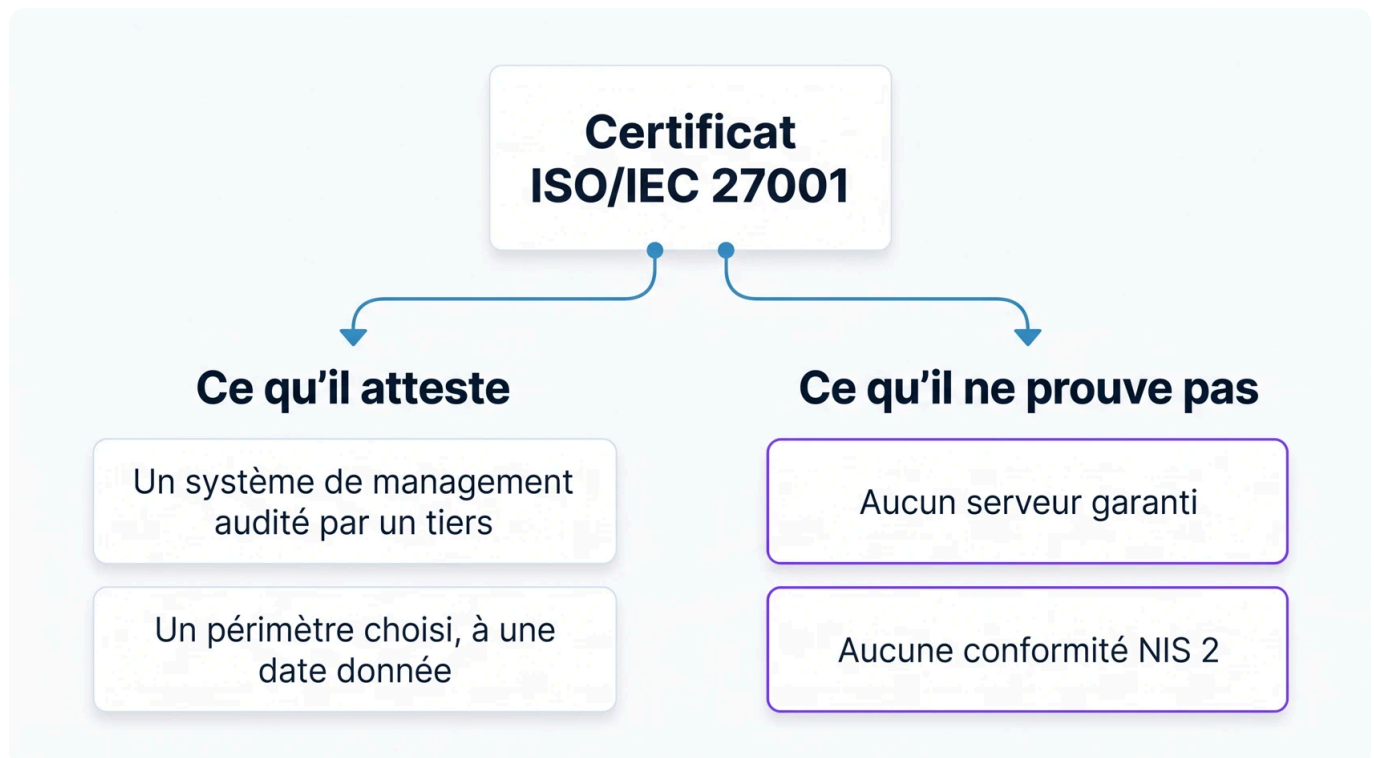


Le point du RSSI : Valeur de la certification ISO 27001

✓ La question qui arrive toujours après le choix



Objectifs de la séance

À l'issue de cette séquence :

- **Expliquer** ce qu'est une certification ISO/IEC 27001 en tant que mécanisme : qui audite, qui certifie, qui surveille les certificateurs
- **Analyser** un périmètre de certification et dire pourquoi deux certificats du même référentiel n'ont pas la même valeur



- **Évaluer** la valeur stratégique d'une certification pour un groupe : ce qu'elle prouve à un client, ce qu'elle ne prouvera jamais à un régulateur
- **Répondre** à une direction pressée sans promettre ce que l'état réel du groupe ne permet pas encore de promettre

Prérequis

- Le choix du référentiel arbitré en séance 3 : ISO/IEC 27001:2022 est la colonne vertébrale du groupe MERIDIAN, et la note d'opportunité l'a fait valider.
- Ce que la certification atteste et n'atteste pas, vu en séance 3 : un tiers, un système de management, un périmètre ; et aucune présomption de conformité NIS 2.
- La gouvernance posée en séance 1 : la Direction Générale fixe l'appétence au risque, le Comité de Direction valide les budgets, le RSSI Groupe élabore et arbitre.

Ce qu'il faut savoir avant l'exercice

Trois compléments suffisent pour traiter le cas du jour. Le reste, la façon dont un audit se conduit réellement, est l'affaire du cours magistral de ce matin.

D'abord, la mécanique de la **certification ISO/IEC 27001**, dont la valeur est connue depuis la séance 3 mais pas encore la tuyauterie. Le problème qu'elle résout est un problème de confiance à grande échelle : n'importe quelle organisation peut déclarer « notre sécurité est bien gérée », et cette déclaration ne vaut rien, précisément parce qu'elle ne coûte rien. La certification remplace la déclaration par une preuve : un **organisme de certification**, tiers et indépendant, vient auditer le système de management contre les exigences de la norme, et délivre, si l'audit conclut à la conformité, un certificat qui engage sa propre réputation. La mécanique a un étage de plus, et c'est lui qui rend l'édifice crédible : les organismes de certification sont eux-mêmes contrôlés. La norme ISO/IEC 27006 fixe, en complément d'ISO/IEC 17021, les exigences applicables aux organismes qui auditent et certifient des SMSI, et sert à leur **accréditation** : le certificateur doit prouver sa compétence et son impartialité avant d'avoir le droit de certifier les autres. La chaîne à trois maillons, à retenir : l'organisation met en œuvre, l'organisme de certification audite et certifie, l'accréditation surveille les certificateurs. La limite du mécanisme, déjà connue : il atteste un système de management sur un périmètre, à une date ; il ne garantit aucun serveur, et il ne remplace aucune obligation légale.



Ensuite, le **périmètre de certification**, qu'il faut maintenant regarder en stratégie et plus seulement en lecteur. Le certificat couvre ce que l'organisation a choisi d'y mettre : une activité, un site, une filiale, un groupe entier. Ce choix est le premier arbitrage économique et politique de tout projet de certification, car l'effort croît avec le périmètre, et la valeur aussi, mais pas au même rythme. Un périmètre étroit se certifie plus vite et rassure moins ; un périmètre large impressionne et peut engloutir deux ans d'énergie. La conséquence pratique, en une phrase héritée de la séance 3 : face à un certificat, on lit le périmètre avant la date ; face à un projet de certification, on dessine le périmètre avant le calendrier.

Périmètre étroit

Se certifie plus vite

Rassure moins

Périmètre large

Impressionne le marché

Peut engloutir deux ans d'énergie

L'effort croît avec le périmètre, la valeur aussi, mais pas au même rythme

Enfin, la **valeur stratégique**, c'est-à-dire ce que le certificat change dans les rapports de force du groupe. Elle tient en trois effets. Effet commercial : le certificat est une preuve opposable dans un appel d'offres, qui évite de répondre à cinquante questionnaires de sécurité par an, ou du moins les abrège. Effet de rareté : d'après l'AFNOR (Association française de normalisation), qui s'appuie sur l'ISO Survey, la France comptait fin 2023 un peu plus d'un millier d'organisations certifiées ISO 27001, trois fois plus qu'en 2019 ; être certifié reste distinctif, et la dynamique, déjà visible en 2020 avec des hausses de 11 % en France et de 22 % dans le monde, dit que les concurrents s'y mettent. Effet interne, le moins visible et le plus durable : l'échéance d'un audit externe discipline une organisation comme aucune note interne ne le fait. Et la limite, apprise en séance 3 et qu'on ne répète jamais assez en comité : la certification ne vaut pas conformité réglementaire. La FAQ NIS 2 de l'ANSSI l'écrit sans détour : « L'obtention d'une certification ISO 27001 ne permet pas, en elle-même, une conformité à NIS 2. » Ce que le référentiel français lui accorde est plus étroit et plus utile : la possibilité de s'en prévaloir pour UN objectif, celui de la gouvernance, sur les systèmes couverts par la certification.

1 000+

ORGANISATIONS CERTIFIÉES
ISO 27001 EN FRANCE FIN
2023 : ÊTRE CERTIFIÉ
RESTE DISTINCTIF

AFNOR, d'après l'ISO Survey

x 3

DE CROISSANCE DU NOMBRE
DE CERTIFIÉS FRANÇAIS
ENTRE 2019 ET FIN 2023

AFNOR, d'après l'ISO Survey

+22 %

DE HAUSSE MONDIALE DES
CERTIFICATIONS DÈS 2020,
+11 % EN FRANCE : LES
CONCURRENTS S'Y METTENT

ISO Survey, 2020

💡 Quand on demande au RSSI Groupe « combien coûte une certification » ou « combien de temps ça prend », la seule réponse professionnelle avant un état des lieux est : « cela dépend du périmètre et de l'écart entre ce que

nous affirmons et ce que nous faisons, et je saurai mesurer cet écart cette semaine ». Un chiffre lancé avant l'audit initial est une dette.

✓ Cas pratique : le tiers exige un certificat, la direction veut le groupe entier

Mise en situation et énoncé

Lundi matin. Deux messages attendent le RSSI Groupe, et ils ne disent pas la même chose.

Le premier vient du Directeur de la filiale instruite : le tiers qui, dans son dossier de filiale (carte du pouvoir, section 3), lui demande une preuve de sécurité, ou dont la filiale redoute qu'il la demande, vient de l'écrire noir sur blanc, et la demande prend la forme classique d'un questionnaire qui s'ouvre par « Êtes-vous certifié ISO/IEC 27001 ? Si oui, joindre le certificat et son périmètre. Si non, décrire les preuves équivalentes. » Le Directeur demande ce qu'on répond pour ne pas perdre le tiers.

Le second vient de la Directrice Générale, qui a lu la note d'opportunité de la séance 3 : « Le comité a validé ta norme. Alors allons au bout : je veux que le groupe soit certifié, toutes filiales, et vite. Dis-moi ce qui nous en sépare. »

Le RSSI Groupe dispose du choix de référentiel validé, de la cartographie de la séance 2, du référentiel importé dans l'outil GRC avec une évaluation de conformité encore vierge, et d'aucun état des lieux mesuré : l'audit initial du groupe commence précisément aujourd'hui.

Questions guidées

1. **Analyser** la question du tiers, une fois celui-ci identifié dans le dossier de filiale : que cherche-t-il à obtenir en demandant le certificat ET son périmètre, et pourquoi la mention « preuves équivalentes » est-elle une porte de sortie honorable pour MERIDIAN ? Lister trois preuves existantes du groupe qui peuvent en tenir lieu aujourd'hui.
2. **Évaluer** la demande de la Directrice Générale : quels sont les deux présupposés discutables de la phrase « le groupe certifié, toutes filiales, et vite » ? S'appuyer sur ce que coûte un périmètre et sur ce qui reste inconnu de l'état réel du groupe.
3. **Proposer** un séquençement de périmètre défendable en comité : quelle filiale ou quelle activité candidate en premier, et pourquoi ? Justifier avec la cartographie de la séance 2 et le contexte réglementaire de chaque filiale, pas avec une préférence.
4. **Corriger** l'enthousiasme du Directeur Administratif et Financier, qui conclut en réunion : « Si on est certifiés, NIS 2 est réglé, autant le budgéter comme un projet de conformité. » Rédiger la mise au point en trois

phrases, exacte juridiquement et utilisable devant un comité.

5. **Formuler** la réponse au tiers en un paragraphe : sans certificat aujourd'hui, sans promesse de date, mais sans laisser la case vide.

Méthode de travail

Traiter les questions dans l'ordre : la question du tiers est la plus facile et elle met les notions en main ; la demande de la Directrice Générale est la plus piègeuse parce qu'elle est flatteuse. Pour chaque réponse, distinguer systématiquement ce que le groupe PEUT prouver aujourd'hui, ce qu'il POURRA prouver après l'état des lieux de cette séance, et ce qui relève d'une décision qui n'est pas encore prise. La décision de certification elle-même, avec son budget et son calendrier, s'instruira quand le groupe construira son SMSI, en séance 8 : la réponse d'aujourd'hui prépare cette décision, elle ne la vole pas. Compter 20 minutes pour les questions 1 à 3, 10 minutes pour les questions 4 et 5.

Corrigés et critères d'évaluation

Corrigé court, question par question

1. La demande du tiers.

- Il reporte son propre risque (fournisseur, conformité, assurance) et achète la preuve la moins chère à vérifier : un audit déjà fait par un organisme accrédité.
- Le périmètre le protège du certificat cosmétique : un certificat « SMSI du siège » ne couvre pas le service rendu par la filiale.
- « Preuves équivalentes » : le tiers évalue une réalité, pas un papier. Trois preuves existantes : la cartographie dans l'outil (séance 2), la note de cadrage et la matrice RACI (séance 1), le référentiel choisi et importé avec son évaluation créée (séance 3).

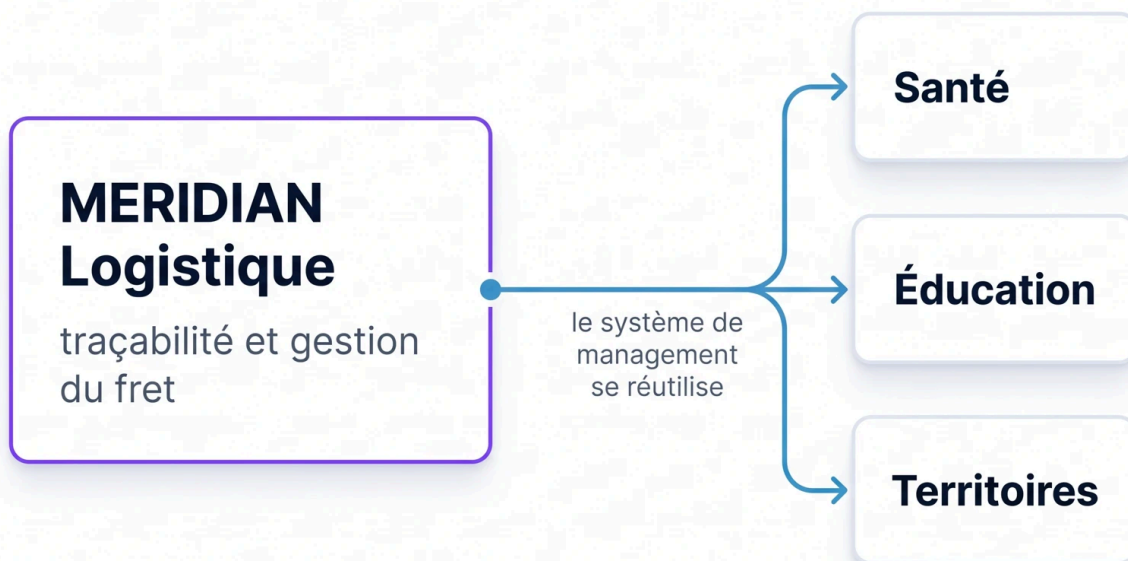
2. Les deux présupposés de « le groupe certifié, toutes filiales, et vite ».

- « Toutes filiales » : le périmètre est un arbitrage effort / valeur, pas une fierté ; le tiers d'une filiale se moque des trois autres.
- « Vite » : l'écart entre ce qu'on affirme et ce qu'on fait est inconnu, l'évaluation est vierge. Réponse attendue : un état des lieux mesuré avant tout calendrier.

3. Le séquençement.

- Croiser trois données : la pression externe, la sensibilité des données, la gagnabilité du premier périmètre.
- Réponse la plus défendable : Logistique d'abord (client pharmaceutique, pénalités, NIS 2), périmètre « transport et entreposage sous température dirigée, WMS et six entrepôts ». « Santé d'abord » recevable

si argumenté par les données ; « tout le groupe d'un coup » irrecevable sans état des lieux.



4. La mise au point NIS 2, en trois phrases.

- La certification ne vaut pas conformité NIS 2 : aucune présomption générale (position de l'ANSSI).
- Elle sert pour un objectif, la gouvernance, sur les seuls systèmes certifiés.
- Budgéter la certification comme un projet de preuve vis-à-vis du marché, la conformité comme un chantier distinct.

5. La réponse au tiers, un paragraphe.

- Pas certifiés à ce jour ; référentiel ISO/IEC 27001:2022 adopté par le comité de direction.
- Preuves disponibles sous accord de confidentialité : cartographie, gouvernance documentée, évaluation outillée.
- État des lieux en cours, conclusions tenues à disposition ; aucune date promise.
- Le tiers dépend du dossier : client pharmaceutique (Logistique), établissements clients (Éducation), collectivité délégante (Territoires), assureur (Santé).

Barème de la page écrite, sur 10

Exactitude et pertinence, 4 points.

- 1 : la chaîne organisation, certificateur, accréditation est restituée.
- 1 : pas de présomption NIS 2 ; un objectif, un périmètre.
- 1 : le périmètre est traité comme un arbitrage, avec un séquençement justifié par le dossier.

- 1 : l'état des lieux est posé comme préalable à tout calendrier.

Posture de RSSI, 3 points.

- 1 : une recommandation explicite à la direction.
- 1 : une réponse au tiers sans case vide, sans bluff, sans date promise.
- 1 : la transposition à la filiale instruite, tiers nommé.

Rédaction, 3 points.

- 1 : une page, lisible par un directeur non technicien.
- 1 : les sigles définis (SMSI, NIS 2, HDS, WMS).
- 1 : pas de recopie du cours, des phrases à soi.